

**UNIVERSIDAD POLITÉCNICA DE
SAN LUIS POTOSÍ**

CARRERA: Ingeniería en Tecnologías de la Información

MATERIA: CNO IV Seguridad Informática

TRABAJO: File path traversal, traversal sequences stripped non-recursively

Ojeda Camacho José Carlos / 181629

PROFESOR: Servando Contreras

Contenido

Información del laboratorio	2
Objetivo del laboratorio.....	2
Explicación técnica de la vulnerabilidad	2
Procedimiento paso a paso	3
Explicación del payload	5
Mitigación recomendada.....	5

Información del laboratorio

- **Nombre del laboratorio:** FILE PATH TRAVERSAL, TRAVERSAL SEQUENCES STRIPPED NON-RECURSIVELY
- **Nivel (Apprentice / Practitioner):** Practitioner
- **Tipo de explotación:** PATH TRAVERSAL

Objetivo del laboratorio

El objetivo de este laboratorio es explotar una vulnerabilidad de *path traversal* en la visualización de imágenes de productos donde la aplicación implementa un filtro débil que elimina las secuencias de escape de directorios de manera no recursiva; para resolverlo, se debe aplicar una técnica de anidación que evada el mecanismo de defensa y permita extraer con éxito el contenido del archivo crítico del sistema operativo, `/etc/passwd`.

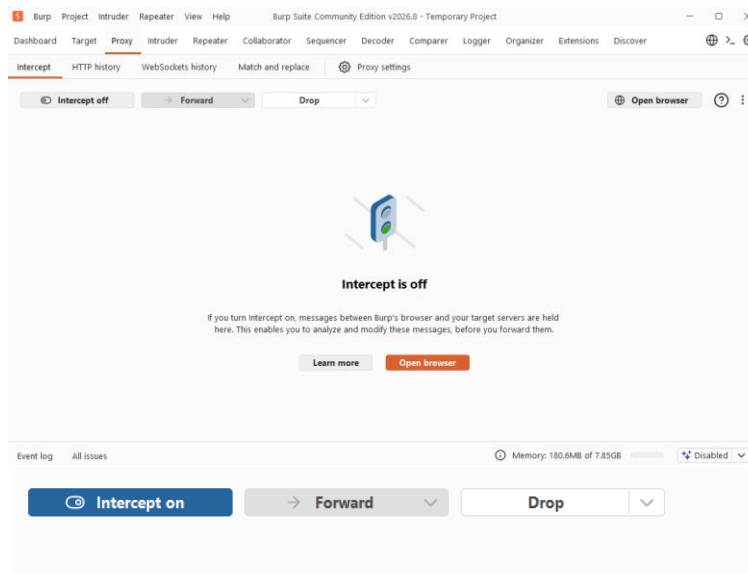
Explicación técnica de la vulnerabilidad

La vulnerabilidad radica en un filtrado insuficiente de las entradas proporcionadas por el usuario. La aplicación web intenta mitigar el riesgo de *path traversal* buscando y eliminando las secuencias de navegación relativa (`../`); sin embargo, dado que este proceso se realiza de forma **no recursiva** y no se ejecuta de manera iterativa hasta que no queden coincidencias, el reemplazo ocurre una sola vez. Al enviar secuencias anidadas (como `....//`), el filtro elimina la subcadena interna, permitiendo que los caracteres restantes se reconecten automáticamente para formar una nueva secuencia de escape válida, lo que posibilita el acceso ilegítimo a archivos sensibles del sistema como `/etc/passwd`.

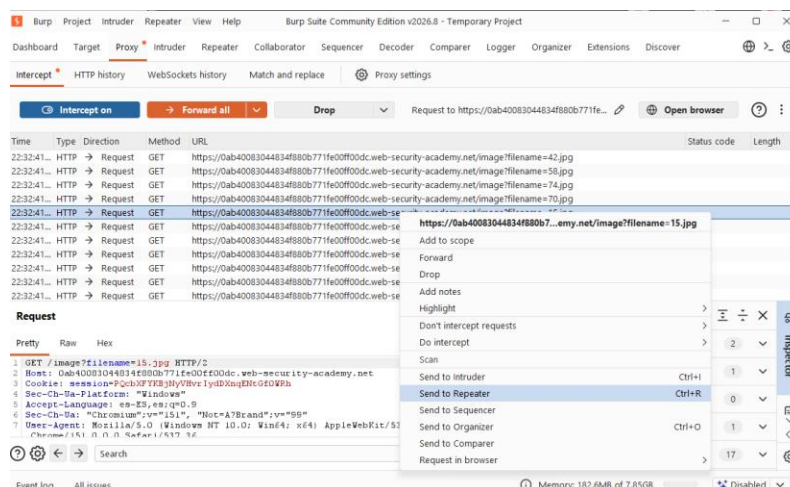
Procedimiento paso a paso

El proceso inicia con la apertura de la aplicación Burp Suite y el uso de su navegador integrado, el cual evita conflictos de configuración con certificados de seguridad.

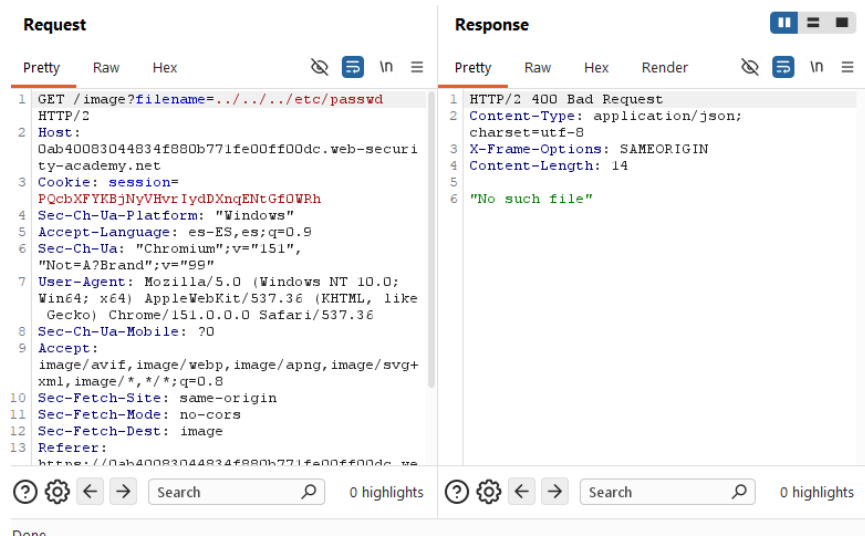
Posteriormente, en la sección **Proxy > Intercept**, se verifica que la función de intercepción se encuentre activada (Intercept is on). Esto permite pausar y capturar de manera temporal las peticiones HTTP generadas por el navegador antes de que alcancen el servidor de la aplicación, facilitando así su análisis y posterior modificación.



Una vez que la intercepción está activa y la petición de carga de imágenes (por ejemplo, GET /image?filename=21.jpg) queda retenida en el panel de control, se hace clic derecho sobre ella para desplegar el menú contextual y se selecciona la opción **Send to Repeater**. Esta acción traslada la petición a la herramienta **Repeater** de Burp Suite, la cual permite reenviar de forma manual y controlada tantas solicitudes como sea necesario, facilitando la prueba de iteraciones y modificaciones en los parámetros sin requerir una nueva interacción directa desde el navegador web.

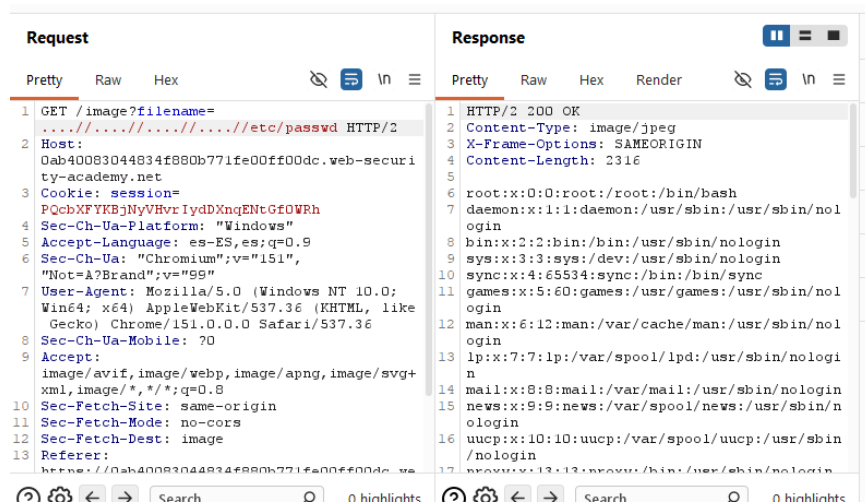


Dentro de la herramienta Repeater, se procede a modificar los parámetros de la petición HTTP capturada. Específicamente, en la solicitud del parámetro filename, se intenta inicialmente con el payload estándar de secuencias relativas: filename=../../../../etc/passwd. Al enviar esta petición, se observa que el filtro de la aplicación detecta y elimina los bloques ../ de manera no recursiva, provocando que la ruta falle y no se logre recuperar el archivo.



Dentro de la herramienta Repeater, se procede a modificar los parámetros de la petición HTTP capturada. Específicamente, en la solicitud del parámetro filename, se reemplaza el nombre del archivo de imagen original por el payload de evasión que utiliza secuencias anidadas y la ruta del archivo objetivo: filename=....//....//....//....//etc/passwd.

Al enviar la solicitud modificada, se observa que el servidor la procesa correctamente y devuelve una respuesta con el código de estado **HTTP/2 200 OK**. En el cuerpo de la respuesta HTTP, el servidor expone el contenido íntegro del archivo /etc/passwd solicitado, mostrando claramente los registros de usuarios del sistema operativo. Esto confirma la explotación exitosa de la vulnerabilidad, demostrando que un atacante puede eludir filtros no recursivos para acceder a archivos restringidos.



Explicación del payload

El payload utilizado en este laboratorio consiste en una secuencia anidada de evasión, específicamente `....//` repetida las veces necesarias antes de la ruta del archivo (`....//....//....//....//etc/passwd`).

Su funcionamiento se debe a que el filtro de la aplicación busca y elimina dinámicamente la secuencia estándar `../` de la cadena de entrada una única vez. Al enviar `....//`, el filtro detecta el `../` central, lo borra, y los caracteres que lo rodeaban (las letras `cc` o puntos restantes) se unen para formar un nuevo `../` que no es analizado nuevamente por el sistema. De este modo, la profundidad de directorios se recorre de manera efectiva hacia la raíz, permitiendo sortear la defensa e interpretar el archivo confidencial solicitado.

Mitigación recomendada

Para prevenir vulnerabilidades de *Path Traversal* con filtros débiles o no recursivos como la analizada en este laboratorio, es necesario implementar un control riguroso sobre la validación y el procesamiento de las entradas del usuario. Las principales medidas de mitigación incluyen:

- **Uso de funciones de mapeo seguro (Basename):** Utilizar funciones integradas en el lenguaje de programación (como `basename()` en PHP) que extraigan únicamente el nombre del archivo solicitado, descartando cualquier ruta o directorio previo proporcionado en el parámetro.
- **Validación mediante listas blancas (Whitelisting):** Restringir los valores permitidos en los parámetros de entrada a un conjunto estricto de nombres de archivos válidos o identificadores predefinidos, rechazando cualquier cadena que contenga caracteres especiales, barras o secuencias de salto de directorio.
- **Directorio raíz confinado (Chroot o aislamiento):** Asegurarse de que la aplicación web se ejecute con privilegios mínimos y que el acceso a los archivos esté estrictamente limitado a un directorio específico del sistema de archivos, impidiendo que el proceso lea fuera de esa estructura autorizada.